

CÓMO IMPLEMENTAR ISO/IEC 27001

Guía práctica para crear, operar, auditar y mejorar un sistema de gestión de seguridad de la información

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

CC BY-NC-SA 4.0

Propósito y aviso importante

Este manual ofrece orientación práctica para implementar ISO/IEC 27001:2022 y su enmienda de acción climática de 2024. No reproduce la norma protegida por derechos de autor ni sustituye la obtención de una copia autorizada. La certificación solo puede ser emitida por un organismo de certificación acreditado después de una auditoría independiente.

***La seguridad humana es lo primero.** Las decisiones de seguridad de la información deben proteger a las personas, la privacidad, la dignidad, los servicios esenciales y los derechos legales.*

Cómo utilizar este manual

- Use los capítulos 1 al 5 para establecer contexto, liderazgo, alcance y gobierno.
- Use los capítulos 6 al 12 para evaluar riesgos, seleccionar controles, operar y crear evidencia.
- Use los capítulos 13 al 17 para auditoría interna, revisión de la dirección, acciones correctivas y preparación para la certificación.
- Adapte cada ejemplo a su organización, obligaciones legales, tecnología y tolerancia al riesgo.

Tabla de contenido

- 1. Comprensión de ISO/IEC 27001
- 2. Principios de implementación y gobierno del proyecto
- 3. Resumen de las cláusulas 4 a 10
- 4. Contexto y partes interesadas
- 5. Alcance del SGSI
- 6. Liderazgo, política y funciones
- 7. Método de evaluación de riesgos
- 8. Tratamiento y Declaración de Aplicabilidad
- 9. Temas de controles del Anexo A
- 10. Información documentada
- 11. Implementación operativa y evidencia
- 12. Competencia, concientización y comunicación
- 13. Monitoreo y métricas
- 14. Auditoría interna
- 15. Revisión por la dirección
- 16. No conformidad y acción correctiva
- 17. Preparación para la certificación
- 18. Hoja de ruta de 30/60/90 días
- 19. Plantillas y listas
- 20. Glosario y referencias

1. Comprensión de ISO/IEC 27001

ISO/IEC 27001 especifica requisitos para un sistema de gestión de seguridad de la información (SGSI). El SGSI es un sistema administrado de políticas, procesos, responsabilidades, decisiones de riesgo, controles, evidencia, monitoreo y mejora. No es solamente una lista de controles ni un proyecto tecnológico.

Concepto	Significado práctico
SGSI	Sistema de gobierno y operación utilizado para administrar riesgos de seguridad de la información.
Enfoque basado en riesgos	Los controles se seleccionan y justifican según riesgos, obligaciones y contexto.
Anexo A	Conjunto de referencia de controles para el tratamiento y la Declaración de Aplicabilidad.
ISO/IEC 27002	Orientación para implementar controles; no es la norma de requisitos de certificación.
Certificación	Confirmación independiente de conformidad dentro de un alcance definido.

Nota sobre la edición vigente

ISO/IEC 27001:2022 es la edición vigente de requisitos. La Enmienda 1:2024 añade consideraciones de acción climática a los requisitos de contexto y partes interesadas. La organización debe determinar si el cambio climático es pertinente para el SGSI y si las partes interesadas tienen requisitos relacionados.

2. Principios de implementación y gobierno

- Trate la implementación como un programa de cambio empresarial.
- Obtenga patrocinio ejecutivo y defina autoridad de decisión.
- Use un equipo multidisciplinario: seguridad, TI, privacidad, legal, RR. HH., compras, instalaciones y operaciones.
- Construya el SGSI alrededor de procesos reales.
- Cree evidencia mientras se realiza el trabajo.
- No afirme que un control es eficaz sin evidencia objetiva.

Función	Responsabilidad habitual
Patrocinador ejecutivo	Recursos, prioridades, aceptación de riesgos y apoyo.
Responsable del SGSI	Plan, coordinación, documentación, métricas y preparación.
Propietarios de riesgos	Evaluar, aceptar o tratar riesgos.
Propietarios de controles	Diseñar, operar, monitorear y mejorar controles.
Auditor interno	Evaluar de forma objetiva e independiente.

Personal y contratistas	Cumplir requisitos, reportar eventos y capacitarse.
-------------------------	---

3. Resumen de las cláusulas 4 a 10

Cláusula	Enfoque de implementación
4 Contexto	Organización, partes interesadas, alcance y procesos.
5 Liderazgo	Compromiso, política, funciones y responsabilidad.
6 Planificación	Riesgos, oportunidades, objetivos, evaluación y tratamiento.
7 Apoyo	Recursos, competencia, concientización, comunicación y documentación.
8 Operación	Ejecución de procesos, evaluaciones, tratamientos y cambios.
9 Evaluación del desempeño	Monitoreo, medición, auditoría interna y revisión.
10 Mejora	No conformidad, acción correctiva y mejora continua.

4. Contexto y partes interesadas

- Identifique cuestiones internas: estrategia, estructura, cultura, tecnología, personal, dependencias e incidentes.
- Identifique cuestiones externas: leyes, reguladores, clientes, proveedores, amenazas, geografía y perturbaciones climáticas pertinentes.
- Identifique partes interesadas y requisitos de seguridad.
- Registre cuáles requisitos se vuelven obligaciones del SGSI.
- Revise el contexto después de cambios importantes y periódicamente.

Parte interesada	Requisito posible
Clientes	Confidencialidad, disponibilidad, notificación y derecho de auditoría.
Reguladores	Salvaguardas, registros, reportes y ubicación de datos.
Empleados	Acceso seguro, privacidad y procedimientos utilizables.
Proveedores	Cláusulas, límites de acceso y coordinación de incidentes.
Dirección	Visibilidad de riesgos, resiliencia y cumplimiento.
Usuarios de servicios esenciales	Continuidad, seguridad, accesibilidad y respuesta responsable.

5. Alcance del SGSI

El alcance define qué cubre el SGSI y qué puede describir una certificación. Debe ser comprensible, defendible y coherente con límites y dependencias reales.

- Defina productos, servicios, procesos, ubicaciones, sistemas, personas y entidades incluidas.
- Documente interfaces con áreas excluidas.
- No excluya procesos solo porque sean difíciles.
- Alinee el alcance con compromisos regulatorios y de clientes.
- Controle el alcance como información documentada.

***Ejemplo:** El SGSI cubre el diseño, desarrollo, alojamiento, soporte y funciones corporativas que respaldan la plataforma SaaS Acme desde Bogotá y entornos de trabajo remoto, incluidos servicios de producción en Azure y proveedores aprobados.*

6. Liderazgo, política y funciones

- Aprobar una política alineada con el propósito y los riesgos.
- Establecer objetivos medibles.
- Asignar autoridad y responsabilidad.
- Integrar seguridad en operaciones y proyectos.
- Proporcionar recursos y eliminar obstáculos.
- Promover reportes sin represalias y mejora continua.

Contenido de la política

- Propósito y compromiso
- Aplicabilidad
- Principios
- Cumplimiento de obligaciones
- Gestión de riesgos
- Funciones
- Reporte de incidentes
- Excepciones y cumplimiento
- Revisión y aprobación

7. Método de evaluación de riesgos

La organización debe definir y aplicar un proceso repetible que produzca resultados consistentes, válidos y comparables.

Paso	Resultado
Establecer criterios	Probabilidad, impacto, aceptación y frecuencia.
Identificar riesgos	Activos o procesos, amenazas,

	vulnerabilidades, consecuencias y propietarios.
Analizar	Probabilidad e impacto inherentes y eficacia de controles existentes.
Evaluar	Comparación con criterios y prioridades.
Registrar	Registro de riesgos aprobado y trazable.

Criterios 5x5 de ejemplo

Puntuación	Probabilidad	Impacto
1	Raro	Interrupción o pérdida insignificante.
2	Improbable	Efecto operativo o financiero limitado.
3	Posible	Efecto material que requiere atención.
4	Probable	Efecto legal, operativo, humano o de clientes serio.
5	Casi seguro	Impacto grave o sostenido, daño importante o consecuencia existencial.

La matriz apoya la consistencia, pero no sustituye el juicio profesional. Documente supuestos e incertidumbre.

8. Tratamiento y Declaración de Aplicabilidad

- Elegir tratamiento: modificar, evitar, compartir/transferir o retener.
- Identificar controles necesarios del Anexo A y otras fuentes.
- Comparar los controles seleccionados con el Anexo A.
- Crear la Declaración de Aplicabilidad (DdA/SoA).
- Justificar inclusiones y exclusiones.
- Definir propietarios, recursos, plazos y aprobación del riesgo residual.

Campo de la DdA	Ejemplo
Referencia	A.5.15 Control de acceso
Aplicable	Sí
Justificación	Reduce acceso no autorizado y cumple obligaciones.
Estado	Implementado / Parcial / Planificado
Propietario	Director de TI
Evidencia	Política, matriz de roles y revisiones trimestrales.
Exclusión	Solo cuando no aplique, con justificación defendible.

9. Temas de controles del Anexo A

El Anexo A de 2022 contiene 93 controles organizados en cuatro temas. No se exige implementar todos de manera ciega; deben determinarse los controles necesarios mediante el tratamiento y justificarse en la DdA.

Tema	Ejemplos
Organizacionales	Políticas, funciones, inteligencia de amenazas, proveedores, incidentes, continuidad y cumplimiento.
Personas	Selección, empleo, concientización, disciplina, trabajo remoto y reporte.
Físicos	Perímetros, entrada, equipos, escritorio limpio, medios, servicios y eliminación.
Tecnológicos	Identidad, autenticación, malware, registros, criptografía, redes, desarrollo y nube.

Registro de implementación de control

- Objetivo y riesgo
- Propietario y operadores
- Procedimiento o configuración
- Frecuencia
- Entradas y salidas
- Evidencia y retención
- Excepciones
- Medida de eficacia
- Fecha de revisión

10. Información documentada

Los documentos explican qué debe ocurrir; los registros demuestran qué ocurrió. Ambos deben controlarse.

Tipo	Ejemplos
Documentos principales	Alcance, política, método, resultados, plan, DdA y objetivos.
Procedimientos	Acceso, cambios, incidentes, copias, proveedores, desarrollo y continuidad.
Registros	Capacitación, aprobaciones, revisiones, pruebas, incidentes y auditorías.
Controles	Aprobación, versión, propietario, acceso, retención, cambios y disposición.

11. Implementación operativa y evidencia

- Convierta controles en tareas rutinarias con propietarios y frecuencias.
- Integre seguridad en incorporación, compras, cambios, desarrollo, operaciones y salida.
- Defina evidencia antes de operar el control.
- Use evidencia automática cuando sea confiable.
- Conserve poblaciones completas para controles muestreados.
- Revise excepciones y fallas en lugar de ocultarlas.
- Controle procesos externalizados.

Prueba de calidad de evidencia

- Pertinente
- Confiable
- Completa
- Trazable
- Protegida

12. Competencia, concientización y comunicación

- Defina competencia para funciones relevantes.
- Evalúe experiencia, capacitación y desempeño.
- Ofrezca educación basada en funciones.
- Conserve evidencia.
- Asegure que el personal comprenda política, contribución y consecuencias.
- Defina qué, cuándo, con quién y cómo se comunica.

13. Monitoreo y métricas

Métrica	Qué puede demostrar
Vulnerabilidades críticas fuera del SLA	Exposición y disciplina de corrección.
Accesos privilegiados revisados	Operación del gobierno de acceso.
Restauraciones exitosas	Capacidad real de recuperación.
Revisiones de proveedores	Cobertura de terceros.
Incidentes detectados y contenidos	Capacidad de detección y respuesta.
Acciones correctivas vencidas	Debilidad en la mejora.
Objetivos logrados	Progreso hacia resultados previstos.

Cada métrica necesita propietario, fuente, cálculo, objetivo, frecuencia, audiencia y acción cuando esté fuera de tolerancia.

14. Auditoría interna

La auditoría interna determina conformidad y eficacia. Los auditores deben ser objetivos e independientes del trabajo auditado.

- Crear un programa basado en riesgos.
- Definir alcance, criterios, métodos, responsabilidades y reporte.
- Revisar documentos y muestras.
- Entrevistar y observar operaciones.
- Registrar conformidades, no conformidades, observaciones y evidencia.
- Verificar el cierre de acciones.

Elemento del hallazgo	Calidad requerida
Requisito	Requisito exacto evaluado.
Evidencia objetiva	Registro, observación, entrevista o configuración específica.
Declaración	Descripción clara de la brecha.
Riesgo o efecto	Por qué importa.
Propietario y fecha	Compromiso responsable.

15. Revisión por la dirección

- Estado de acciones anteriores
- Cambios de contexto y requisitos
- Desempeño y tendencias
- Resultados de auditoría
- Objetivos
- Retroalimentación
- Estado de riesgos y tratamientos
- Oportunidades de mejora
- Recursos y decisiones necesarias

Las salidas deben incluir decisiones, responsables, recursos y cambios. Conserve actas o evidencia equivalente.

16. No conformidad y acción correctiva

- Reaccionar y controlar.
- Corregir y atender consecuencias.
- Determinar causa raíz y alcance.
- Planificar una acción proporcional.
- Implementar.
- Verificar eficacia.
- Actualizar riesgos, controles y documentación.

Respuesta débil: "Recordar al empleado." **Respuesta más sólida:** identificar por qué falló el proceso, rediseñar el flujo, capacitar y verificar eficacia.

17. Preparación para la certificación

- Seleccionar un organismo acreditado.
- Completar auditoría interna y revisión de la dirección.
- Mantener actualizados riesgos, DdA, objetivos, controles y evidencia.
- Cerrar o administrar brechas importantes.
- Preparar al personal para explicar responsabilidades reales.
- Comprender que la Etapa 1 evalúa preparación y diseño, y la Etapa 2 implementación y eficacia.
- Nunca fabricar ni retrofechar evidencia.

Fallas comunes

- Alcance que no coincide con operaciones.
- Registro de riesgos y DdA desconectados.
- Controles sin evidencia.
- Propietarios que desconocen funciones.
- Riesgos de proveedores o nube incompletos.
- Auditoría interna sin independencia.
- Revisión sin decisiones.
- Acciones cerradas sin verificar eficacia.

18. Hoja de ruta de 30/60/90 días

Días 1-30: base

- Nombrar patrocinador y responsable.
- Definir gobierno.
- Identificar contexto, partes, obligaciones y alcance.
- Realizar análisis de brechas.
- Aprobar método de riesgos y control documental.
- Crear registro de implementación.

Días 31-60: evaluar e implementar

- Completar evaluación.
- Desarrollar tratamiento y DdA.
- Asignar propietarios.
- Priorizar controles de alto riesgo.
- Crear políticas y procedimientos esenciales.
- Iniciar evidencia y concientización.

Días 61-90: verificar y mejorar

- Medir objetivos y operación.
- Completar auditoría interna.
- Corregir brechas.

- Realizar revisión de la dirección.
- Verificar acciones.
- Tomar decisión de preparación y plan de mejora.

19. Plantillas y listas

Lista mínima de implementación

- ☐ Contexto y partes documentados
- ☐ Pertinencia climática considerada
- ☐ Alcance aprobado
- ☐ Política aprobada
- ☐ Funciones asignadas
- ☐ Criterios de riesgo aprobados
- ☐ Evaluación completada
- ☐ Plan aprobado
- ☐ DdA completada
- ☐ Objetivos y métricas
- ☐ Procedimientos operativos
- ☐ Evidencia retenida
- ☐ Competencia y concientización
- ☐ Auditoría interna
- ☐ Revisión de la dirección
- ☐ Acciones verificadas
- ☐ Organismo y alcance confirmados

Campos del registro de riesgos

Campo	Propósito
ID	Trazabilidad.
Proceso o activo	Ubicación del riesgo.
Amenaza y vulnerabilidad	Causa o condición.
Consecuencia	Efecto empresarial o humano.
Propietario	Responsabilidad de decisión.

Riesgo inherente	Antes de controles.
Controles existentes	Salvaguardas actuales.
Riesgo residual	Después de controles.
Tratamiento	Acción, responsable, fecha y estado.
Aceptación	Decisión autorizada.

20. Glosario y referencias oficiales

Término	Definición
SGSI	Sistema de gestión de seguridad de la información.
DdA/SoA	Declaración de Aplicabilidad.
Conformidad	Cumplimiento de un requisito.
No conformidad	Incumplimiento de un requisito.
Acción correctiva	Acción para eliminar la causa y evitar recurrencia.
Riesgo residual	Riesgo restante después de controles.
Parte interesada	Persona u organización que afecta o puede ser afectada por el SGSI.

[Página oficial ISO/IEC 27001:2022](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[Página oficial ISO/IEC 27002:2022](#)

[Familia ISO/IEC 27000](#)

[ISO 19011 - directrices de auditoría](#)

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0. Las normas ISO están protegidas por derechos de autor; obtenga copias autorizadas de ISO o de un organismo nacional de normalización.